ПОЛИТИКА ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

Информационная система платформы _____

Оператор: _____

Ответственный за обеспечение информационной безопасности: _____

Дата вступления в силу: «___» _____ 20___ года

1. Общие положения

1.1. Настоящая Политика информационной безопасности (далее Политика ИБ) определяет цели, принципы, организационные и технические меры по обеспечению безопасности информации в информационной системе Сайта, включая веб-приложение, серверную инфраструктуру, базу данных и связанные компоненты, а также обработку персональных данных (ПДн).

1.2. Политика ИБ разработана в соответствии с Федеральным законом № 152-ФЗ «О персональных данных», Федеральным законом № 149-ФЗ «Об информации, информационных технологиях и о защите информации», Постановлением Правительства Российской Федерации от 01.11.2012 № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных» (Собрание законодательства Российской Федерации, 2012, № 45, ст. 6257), а также учитывает подходы к защите информации, изложенные в приказе ФСТЭК России от 18.02.2013 № 21 «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных». Указанный приказ определяет меры для каждого из уровней защищённости, установленных Постановлением № 1119, и прямо не рассматривает меры, связанные с применением шифровальных (криптографических) средств защиты информации. Приказ ФСТЭК России от 11.04.2025 № 117 «Требования о защите информации, содержащейся в государственных информационных системах, иных информационных системах государственных органов, государственных унитарных предприятий, государственных учреждений» на настоящую Платформу не распространяется и используется только как методический ориентир: его пункт 14 задаёт состав политики защиты информации, внутренних стандартов и внутренних регламентов, а пункт 5 прямо относит системы, содержащие персональные данные, к требованиям по защите персональных данных. Дополнительно учтены ГОСТ Р ИСО/МЭК 27005 и перечень актуальных угроз OWASP Top 10.

1.3. Цели Политики ИБ: обеспечение конфиденциальности, целостности и доступности информации (триада CIA); предотвращение несанкционированного доступа, модификации, уничтожения и блокирования информации; защита прав субъектов персональных данных; минимизация рисков от актуальных угроз; соответствие законодательству Российской Федерации.

1.4. Область применения: Сайт, все его компоненты и связанные информационные системы на всех этапах жизненного цикла.

1.5. Порядок обработки персональных данных, перечень ПДн, цели, сроки хранения и права субъектов определены Политикой конфиденциальности (Приложение № 1 к Условиям использования). Настоящая Политика ИБ определяет меры по защите информации.

1.5.1. Оператор действует как физическое лицо и не осуществляет предпринимательскую деятельность: платные услуги не оказываются, сделки за плату не совершаются, доход от деятельности не получается, признаки предпринимательской деятельности, установленные статьёй 2 Гражданского кодекса Российской Федерации, отсутствуют. Оператор не использует Платформу для извлечения прибыли и не осуществляет рекламную рассылку в отношении несовершеннолетних Пользователей. При возникновении дохода Оператор регистрируется в качестве индивидуального предпринимателя до его получения и дополняет настоящие документы сведениями об ОГРНИП.

1.6. Основные понятия:

Понятие	**Определение**
Информация	Сведения (сообщения, данные) независимо от формы представления.
Информационная система	Совокупность содержащихся в базах данных информации и обеспечивающих её обработку технологий и технических средств.
Доступ к информации	Возможность получения информации и её использования.
Конфиденциальность информации	Требование не передавать информацию третьим лицам без согласия её обладателя.
Предоставление информации	Действия, направленные на передачу информации определённому кругу лиц.
Распространение информации	Действия, направленные на передачу информации неопределённому кругу лиц.
Электронное сообщение	Информация, переданная или полученная по сети Интернет.

2. Классификация информации, обрабатываемой в информационной системе

2.1. Общедоступная информация: информация, доступ к которой предоставлен неограниченному кругу лиц без прохождения аутентификации.

2.1.1. Состав: справочные материалы Платформы, открытое описание Платформы, юридические документы (Условия использования, Политика конфиденциальности, согласия). Публикация персональных данных Оператором не осуществляется.

2.1.2. Ограничение доступа к общедоступной информации не допускается, если иное не предусмотрено законодательством. Публикация персональных данных не осуществляется; при её введении потребуется отдельное согласие субъекта на распространение персональных данных.

2.2. Информация ограниченного доступа (конфиденциальная).

2.2.1. Персональные данные: никнейм, адрес электронной почты, хеш пароля, количество полных лет, сведения анкеты, игровые и обучающие данные, обращения к ИИ-помощнику, технические данные пользователей.

2.2.2. Служебная и технологическая информация: ключи доступа к внешним сервисам (в том числе к сервису ИИ-помощнику), учётные данные администратора базы данных, пароли доступа к серверу и панели управления, конфигурационные файлы, содержащие параметры подключения.

2.2.3. Логи и события безопасности: серверные журналы посещений, содержащие IP-адреса и идентификаторы сессий; журналы приложений; события аутентификации.

2.3. Техническая (служебная) информация: метаданные файлов, структура базы данных (имена таблиц, индексы), версии программного обеспечения, внутренние сетевые параметры, временные файлы и кэш. Указанная информация не содержит ПДн в явном виде, но её разглашение может привести к нарушению работоспособности информационной системы.

2.3.1. Тренировочный датасет ходов: позиция до и после хода, ход Пользователя, оценка позиции, идентификатор игровой сессии и идентификатор учётной записи. Датасет относится к информации ограниченного доступа, хранится в базе данных на территории Российской Федерации и защищается мерами настоящей Политики наравне с персональными данными. Выгрузка датасета допускается только по решению Оператора и только после обезличивания сведений, позволяющих установить принадлежность записи конкретному Пользователю.

3. Актуальные угрозы безопасности

3.1. Модель угроз безопасности персональных данных утверждена Оператором. Модель угроз информационной системы определяется с учётом результатов периодического анализа кода.

3.2. Угрозы уровня веб-приложения:

Класс уязвимости (CWE)	**Описание**	**Меры**
CWE-20	Некорректная проверка входных данных	серверная валидация и типизация входных параметров; ограничение длины и диапазона значений
CWE-78	Внедрение команд в операционную систему сервера	использование параметризованных запросов; отсутствие сборки команд из пользовательского ввода
CWE-79	Межсайтовое исполнение сценариев (XSS)	экранирование выводимых данных; строгая политика безопасности содержимого (CSP); запрет опасных вставок
CWE-22, CWE-23, CWE-36	Path traversal: получение доступа к файлам, не принадлежащим	нормализация и проверка путей; работа только с предопределёнными

	Пользователю	наборами файлов (например, ресурсами фигур и досок)
CWE-918	Недоверенные внешние запросы (SSRF): сервер отправляет запросы к внутренним или внешним ресурсам от своего имени	белый список допустимых внешних адресов; запрет обращений к внутренней сети и метаданным облака
CWE-730	Отказ в обслуживании (DoS)	ограничение частоты запросов (rate limiting); защита на уровне сетевого периметра
CWE-312, CWE-259, CWE-798	Пароли, токены или ключи API сохранены в журналах, захардкожены в коде или переданы по незащищённому каналу	запрет вывода секретов в журналы; хранение секретов в переменных окружения и конфигурации, не попадающих в систему контроля версий; регулярная ротация ключей
CWE-352	Подделка межсайтовых запросов (CSRF)	использование токенов доступа в заголовке авторизации; проверка происхождения запросов

3.3. Угрозы инфраструктуре: атаки типа «отказ в обслуживании», компрометация серверов, перехват трафика.

3.4. Угрозы данным: утечки персональных данных (внутренние и внешние), несанкционированный доступ к базе данных, перехват ключей доступа, утечка через резервные копии.

3.5. Угрозы цепочки поставок: компрометация сторонних библиотек и зависимостей, небезопасные обновления.

3.6. Угрозы, связанные с особенностями платформы: компрометация учётной записи Пользователя; злоупотребление функцией ИИ-помощника для рассылки недопустимого содержания; подмена игровых показателей.

4. Организационные меры по обеспечению информационной безопасности

4.1. Назначен ответственный за информационную безопасность и организацию обработки персональных данных: _____. Контакты: _____.

4.2. Разграничение прав доступа (ролевая модель):

Роль	**Уровень доступа**
Администратор	Расширенный доступ к административной части информационной системы и данным, необходимым для администрирования
Разработчик	Доступ к исходному коду и тестовому окружению; доступ к продуктивным данным ограничен
Пользователь	Доступ только к своим данным и к общедоступному

	контенту

4.2.1. Матрица ролей и прав утверждается внутренним актом Оператора и пересматривается при изменении состава привлекаемых лиц, функциональности Платформы или уровня защищённости персональных данных.

4.3. Принципы доступа: принцип минимальных привилегий; принцип необходимости знания; запрет на доступ к персональным данным лиц, которым он не требуется.

4.4. Контроль удалённого и привилегированного доступа: доступ к административной части Платформы и к серверу осуществляется по защищённому каналу; доступ к серверу осуществляется по ключам; журналирование административных действий обязательно.

4.5. Управление изменениями: изменения кода и конфигурации проходят через тестовое окружение с последующей проверкой перед применением в продуктивной среде; перед изменениями выполняется резервное копирование; журнал изменений ведётся не менее 12 месяцев; изменения, затрагивающие обработку персональных данных, предварительно оцениваются на предмет необходимости актуализации настоящей Политики.

4.6. Работа с Обработчиками: обработка персональных данных поручается лицам на основании договоров, предусматривающих конфиденциальность, требования к защите и обязанность уведомлять об инцидентах. Перечень Обработчиков приведён в Приложении № 3 к Условиям использования и размещается на Сайте отдельной страницей.

4.7. Обучение и осведомлённость: лица, непосредственно осуществляющие обработку персональных данных, знакомятся с требованиями законодательства и Политикой ИБ и проходят обучение: не реже одного раза в год.

4.8. Внутренний контроль: соответствие порядка обработки персональных данных требованиям законодательства и Политики конфиденциальности проверяется не реже одного раза в 6 месяцев.

4.9. Внутренние локальные акты

4.9.1. Оператор принимает и поддерживает в актуальном состоянии следующие внутренние акты, все из которых обязательны:

- модель актуальных угроз безопасности персональных данных;
- перечень персональных данных по целям обработки и категориям субъектов (Приложение 1.1 к Политике конфиденциальности);
- порядок уничтожения персональных данных;
- положение о внутреннем контроле обработки персональных данных;
- приказ о назначении ответственного за организацию обработки персональных данных;
- регламент реагирования на инциденты и направления уведомлений;
- план управления рисками с пересмотром не реже одного раза в 6 месяцев;

- матрица прав доступа, утверждаемая локальным актом Оператора;
- журнал изменений, ведущийся не менее 12 месяцев;
- акт об определении уровня защищённости персональных данных.

4.9.2. Перечисленные акты принимаются в порядке, установленном Оператором, и подлежат актуализации при изменении состава Обработчиков, технической архитектуры Платформы и уровня защищённости персональных данных.

5. Технические меры защиты

5.1. Защита периметра и сети: обслуживание Сайта по защищённому каналу (HTTPS); применение межсетевого экрана с правилами против внедрения команд, межсайтового исполнения сценариев и отказа в обслуживании (внедрение и настройка Web Application Firewall средствами хостинг-провайдера либо средствами сервера); защита от распределённых атак типа «отказ в обслуживании» средствами сетевого периметра либо провайдера; сегментация сети: размещение базы данных в отдельном сегменте (контейнере), недоступном из публичной сети, изоляция административных зон; ограничение доступных сетевых портов.

5.2. Шифрование информации: обязательное шифрование канала передачи данных с использованием современных версий протокола транспортной безопасности (TLS), механизма строгого транспорта (HSTS), механизма проверки отзыва сертификата (OCSP Stapling) и сертификатов доверенных удостоверяющих центров; шифрование носителей информации серверов; хранение паролей в виде необратимых хеш-функций с механизмом затруднения подбора (например, bcrypt или Argon2).

5.3. Управление доступом и аутентификация: доступ к серверу и административной части информационной системы осуществляется по ключам доступа, а не по паролям; для привилегированных учётных записей применяется многофакторная аутентификация; устанавливаются ограничения частоты попыток входа и автоматическая блокировка источника при множественных неудачных попытках; токен доступа передаётся только в заголовке авторизации и не выводится в журналы; срок действия токена ограничен.

5.4. Защита от вредоносного кода и уязвимостей: регулярное (не реже одного раза в месяц) обновление программного обеспечения, библиотек и зависимостей; периодическое сканирование уязвимостей информационной системы и зависимостей; контроль целостности конфигурационных файлов; проверка и ограничение типов и размеров загружаемых файлов; антивирусная защита серверов; проверка входных данных на сервере; использование параметризованных запросов; экранирование выводимых данных; белый список внешних адресов, к которым обращается сервер.

5.5. Регистрация событий и мониторинг: централизованное логирование событий доступа, изменений данных, ошибок и подозрительного трафика; хранение журналов не менее 12 месяцев с защитой от их последующей модификации; настройка автоматических оповещений ответственного за информационную безопасность о критических событиях (множественные неудачные попытки входа, аномальный трафик, массовые обращения к персональным данным).

5.6. Безопасность приложения: установление строгой политики безопасности содержимого (Content-Security-Policy); заголовок Referrer-Policy со значением no-referrer; запрет кэширования

ответов, содержащих персональные данные и данные авторизации; запрет размещения на Сайте ресурсов сторонних сервисов (библиотек, шрифтов, виджетов), загружаемых с внешних доменов; разграничение доступа к административной части; хранение параметров подключения и ключей доступа к внешним сервисам в конфигурации, не попадающей в систему контроля версий; регулярная ротация ключей доступа.

5.7. Хранение и резервирование: база данных и резервные копии размещаются на территории Российской Федерации; резервное копирование выполняется регулярно, в том числе перед внесением изменений, восстанавливаемость проверяется периодически.

5.8. Уничтожение данных: уничтожение персональных данных осуществляется программными средствами, исключающими восстановление; резервные копии, содержащие уничтоженные данные, уничтожаются в течение не более 30 дней с момента уничтожения.

5.9. Обеспечение доступности: контроль работоспособности Платформы; мониторинг ошибок; восстановление сервисов после сбоев.

5.10. Статический анализ программного кода. В информационной системе применяется автоматизированный анализ исходного кода на наличие типовых уязвимостей. Анализ проводится не реже одного раза в год, а также после существенных изменений в программном коде.

5.11. Защита мобильных и конечных устройств. Требования настоящего раздела распространяются на устройства, с которых Пользователь получает доступ к информационной системе Платформы, в том числе на мобильные устройства, планшеты и переносные компьютеры, а также на приложение Платформы для мобильных операционных систем:

- мобильное приложение распространяется только через официальные магазины приложений; установка приложения из иных источников не допускается;
- приложение не хранит персональные данные и учётные данные на устройстве в открытом виде, пароль и иные секреты не сохраняются в памяти устройства;
- соединение приложения с серверной частью осуществляется по защищённому каналу; передача персональных данных открытым текстом не допускается;
- приложение использует системные механизмы защиты: межпроцессную изоляцию, защищённое хранилище, контроль целостности;
- на устройстве устанавливается блокировка экрана, актуальная версия операционной системы и антивирусное программное обеспечение;
- при утрате устройства Пользователь обязан сообщить об этом Оператору по контактам для обращений; Оператор прекращает выдачу токенов доступа к учётной записи Пользователя и инициирует процедуру восстановления доступа.

6. Управление инцидентами

6.1. Под инцидентом информационной безопасности понимается событие, при котором произошли неправомерный доступ к персональным данным, их неправомерная передача (предоставление, распространение, доступ), уничтожение, модификация, блокирование либо компрометация учётных данных.

6.2. Классификация инцидентов:

Категория	**Признаки**
Критический	Утечка персональных данных; компрометация сервера или базы данных; недоступность Платформы, затрагивающая права Пользователей
Высокий	Компрометация учётной записи привилегированного пользователя; компрометация учётной записи Пользователя с доступом к персональным данным
Средний	Нарушение настоящей Политики ИБ; попытка несанкционированного доступа, не приведшая к утечке; несанкционированное использование ресурсов Платформы
Низкий	Неработоспособность отдельных компонентов Платформы; отказ в обслуживании без последствий для персональных данных

6.2.1. Оператор обеспечивает взаимодействие с государственной системой обнаружения, предупреждения и ликвидации последствий компьютерных атак на информационные ресурсы Российской Федерации (далее ГосСОПКА), включая информирование о компьютерных инцидентах, повлёкших неправомерную передачу (предоставление, распространение, доступ) персональных данных, в порядке, определяемом федеральным органом исполнительной власти, уполномоченным в области обеспечения безопасности (часть 12 статьи 19 Федерального закона от 27.07.2006 № 152-ФЗ). Порядок передачи соответствующих сведений устанавливается совместно указанным органом и уполномоченным органом по защите прав субъектов персональных данных (часть 14 статьи 19 Федерального закона от 27.07.2006 № 152-ФЗ). Порядок такого взаимодействия определён приказом ФСБ России от 13.02.2023 № 77, утвердившим порядок взаимодействия операторов с государственной системой обнаружения, предупреждения и ликвидации последствий компьютерных атак, включая информирование ФСБ России о компьютерных инцидентах, повлёкших неправомерную передачу (предоставление, распространение, доступ) персональных данных. Перечень и сроки уведомлений приведены в разделе 6.4 и в Регламенте реагирования на инциденты.

6.3. Порядок реагирования. При возникновении инцидента ответственный за информационную безопасность инициирует следующие этапы:

- обнаружение и немедленное уведомление ответственного за информационную безопасность;
- определение категории инцидента, оценка масштаба и круга затронутых персональных данных;
- локализация (изоляция затронутого сегмента информационной системы и прекращение неправомерного доступа);
- устранение причин и ликвидация последствий;

- восстановление целостности данных и работоспособности Платформы;
- уведомление уполномоченного органа и затронутых субъектов персональных данных в соответствии с разделом 11.6 Политики конфиденциальности;
- пост-анализ (разбор причин, оценка допущенных ошибок) и подготовка отчёта;
- актуализация модели угроз и корректировка мер защиты.

6.4. Порядок действий при утечке персональных данных.

6.4.1. При установлении факта неправомерной или случайной передачи (предоставления, распространения, доступа) персональных данных, повлёкшей нарушение прав субъектов персональных данных, Оператор обязан с момента выявления такого инцидента уведомить уполномоченный орган по защите прав субъектов персональных данных (часть 3.1 статьи 21 Федерального закона от 27.07.2006 № 152-ФЗ):

- в течение 24 (двадцати четырёх) часов: о произошедшем инциденте, о предполагаемых причинах, повлёкших нарушение прав субъектов персональных данных, и предполагаемом вреде, нанесённом правам субъектов персональных данных, о принятых мерах по устранению последствий соответствующего инцидента, а также сведения о лице, уполномоченном Оператором на взаимодействие с уполномоченным органом по защите прав субъектов персональных данных по вопросам, связанным с выявленным инцидентом;
- в течение 72 (семидесяти двух) часов: о результатах внутреннего расследования выявленного инцидента, а также сведения о лицах, действия которых стали причиной выявленного инцидента (при наличии).

6.4.2. Оператор обеспечивает взаимодействие с ГосСОПКА, включая информирование о компьютерных инцидентах, повлёкших неправомерную передачу (предоставление, распространение, доступ) персональных данных, в порядке, определяемом федеральным органом исполнительной власти, уполномоченным в области обеспечения безопасности (часть 12 статьи 19 Федерального закона от 27.07.2006 № 152-ФЗ).

6.4.3. При выявлении неправомерной обработки персональных данных Оператор обязан прекратить её в срок, не превышающий 3 (трёх) рабочих дней с даты выявления; в случае если правомерность обработки не может быть восстановлена, Оператор уничтожает персональные данные в срок, не превышающий 10 (десяти) рабочих дней с даты выявления неправомерной обработки, и уведомляет об этом затронутых субъектов персональных данных (часть 3 статьи 21 Федерального закона от 27.07.2006 № 152-ФЗ).

6.5. По результатам инцидента проводится разбор причин, фиксируются выявленные недостатки мер защиты и принимается решение об их устранении.

7. Контроль и совершенствование

7.1. Менеджмент рисков информационной безопасности осуществляется в соответствии с подходами ГОСТ Р ИСО/МЭК 27005 и является непрерывным итерационным процессом.

7.2. Политика ИБ пересматривается ежегодно, а также при внесении существенных изменений в функциональность Платформы, изменении состава Обработчиков или по результатам инцидентов. При пересмотре проверяется соответствие Политики актуальным требованиям законодательства и внутренним актам Оператора.

7.3. Аудит выполнения мер по обеспечению информационной безопасности проводится не реже одного раза в 6 месяцев, а также при изменении состава Обработчиков, функциональности Платформы или по результатам инцидентов. Результаты аудита оформляются внутренним актом Оператора.

7.4. Для непрерывного совершенствования мер применяется цикл PDCA (Plan-Do-Check-Act): планирование мер, их выполнение, проверка результатов и последующая корректировка.

7.5. Периодический анализ уязвимостей информационной системы проводится не реже одного раза в год, а также после внесения существенных изменений.

7.6. Модель угроз, модель нарушителя и перечень актуальных угроз актуализируются при изменении состава Обработчиков, появлении новых функций Платформы или по результатам инцидентов.

8. Ответственность

8.1. Лица, имеющие доступ к информационной системе, обязаны соблюдать требования настоящей Политики ИБ. Нарушение требований влечёт ответственность, установленную законодательством Российской Федерации, а также принятыми Оператором мерами.

8.2. Ответственность за нарушение требований законодательства о персональных данных устанавливается в соответствии с законодательством Российской Федерации.

8.3. Настоящая Политика ИБ подлежит применению всеми лицами, привлекаемыми к обслуживанию информационной системы по договорам.

С перечнем ПДн, целями и сроками обработки следует ознакомиться в Политике конфиденциальности (Приложение № 1 к Условиям использования).

Проект документа. Поля, обозначенные «_____», подлежат заполнению Оператором до вступления документа в силу.